

Advanced Security and Privacy

Informationssicherheits-Risikomanagement

Dipl. Ing. Dr. Kevin Theuermann MSc

Definition Risiko

Duden:

möglicher negativer Ausgang bei einer Unternehmung, mit dem Nachteile, Verlust, Schäden verbunden sind; mit einem Vorhaben, Unternehmen o. Ä. verbundenes Wagnis

ISO 27005:2022:

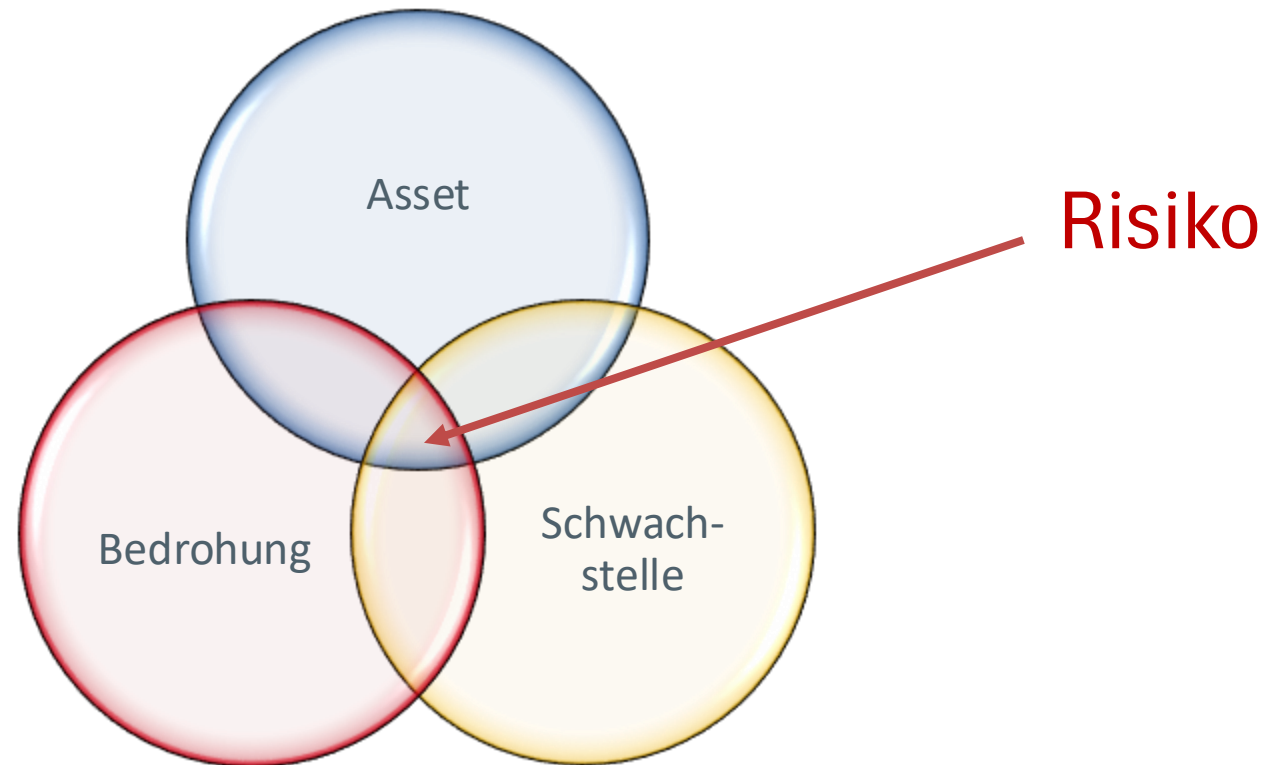
effect of uncertainty on objectives

Note 1 to entry: An effect is a deviation from the expected, **positive or negative**.

Note 5 to entry: In the context of information security management systems, information security risks can be expressed as effect **of uncertainty on information security objectives**. Note 6 to entry: Information security risks **are usually associated with a negative effect** of uncertainty on information security objectives.

Grundvoraussetzungen für ein Risiko

Wie entsteht ein Risiko?



Für ein Risiko müssen alle drei Voraussetzungen erfüllt sein!

Beispiele für Bedrohungen und Schwachstellen

Asset	Bedrohung	Schwachstelle
Unternehmensgebäude, Büroräume, Fertigungshalle, Serverraum	Feuer	Fehlende Brandschutzmaßnahmen
Serverraum, Server	Ausfall der Stromversorgung	Keine redundante Stromversorgung, keine USV
Server, Applikationen	Malware	Unzureichende Wartung, fehlendes Patchmanagement, veraltete Systeme
File Server, Laufwerke	Fehler bei der Datenspeicherung, korrupte Daten, mutwillige Zerstörung von Daten	Fehlende Datensicherung, Fehlende Restore-Tests
Server, Applikationen, Netzwerke	Hacking	Software-Schwachstellen, Software-Fehler, ungeschützte Netzwerke, fehlendes Logging, schwache Login-Verfahren
ERP-System, SAP, Laufwerke	Mutwillige Zerstörung von Daten durch ehemalige Mitarbeiter	Fehlende Prozesse zum Rechteentzug, fehlendes Logging, fehlende Backups

Übungsbeispiel

Unterschied Bedrohung – Schwachstelle – Risiko

1. Der Reifen hat kaum noch Profil.
 2. Die Tür zum Warenlager steht häufig offen.
 3. Die Aktivität von Cyberterroristen hat zugenommen.
 4. Der entlassene Mitarbeiter hat gedroht, geheime Finanzdaten zu veröffentlichen, indem er die ihm bekannten technischen Schwachstellen ausnützt.
 5. Ein erfolgreicher Cyberangriff hat unsere Webseite für mehrere Stunden lahmgelegt.
 6. Der unter Punkt 5 genannte Angriff könnte zukünftig wieder passieren.
 7. Ein Anrufer könnte mittels Social Engineering Kennworte erfahren und somit Remotezugang zu den Buchhaltungsdaten gewinnen.
-

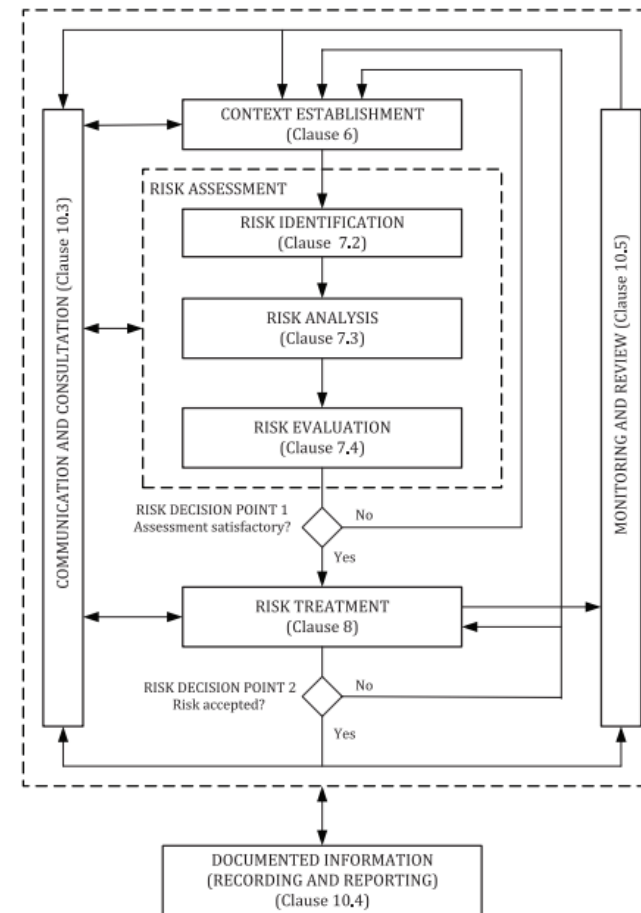
Weshalb Risikomanagement?

Systematische Methode, um Risiken auch bei großer Zahl, Komplexität und damit Unüberschaubarkeit sinnvoll und vernünftig zu verwalten

- ✓ Systematische Erfassung von Risiken
- ✓ Vergleichbare Bewertung von Risiken, die eine
- ✓ Ermöglichung einer Priorisierung
- ✓ Geregelte Kommunikation von Risiken
- ✓ Formelle Entscheidung zur Risikobehandlung
- ✓ Definierte Verantwortliche (Risiko-Eigner, Risikomanager)
- ✓ Regelmäßige Kontrolle / Bewertung ob
 - sich die bestehenden Risiken geändert haben
 - ob neue Risiken dazugekommen sind

Risikomanagement Big Picture

- ✓ Bestimmung des Kontexts
- ✓ Risikoidentifikation
- ✓ Risikoanalyse
- ✓ Risikoevaluierung
- ✓ Risikobehandlung
- ✓ Risikokommunikation
- ✓ Überwachung und Verbesserung



Bestimmung des Kontexts des Risikomanagementsystems

Bestimmung des Kontexts

Festlegung des Geltungsbereichs (Scope)

- Definition, welche Teile der Organisation unter das Risikomanagement fallen
 - Organisatorisch: Bereiche, Abteilungen, etc.
 - Physisch: Standorte, Gebäude
 - Technisch: Systeme, technische Einrichtungen

Organisatorische Überlegungen

- Festlegung der Rollen
 - Wer ist für das Risikomanagement verantwortlich (Risikomanager)
 - Wer trägt die Risiken als Letztverantwortliche(r) (Risiko-Eigner)
-

Festlegungen der Rahmenbedingungen

Beispiel einer Bewertungsskala für die Beschreibung der Eintrittswahrscheinlichkeit

	Bezeichnung	Beschreibung Eintrittswahrscheinlichkeit (ETW)
4	sehr hoch	Eintritt sehr wahrscheinlich
3	hoch	Eintritt wahrscheinlich
2	mittel	Eintritt eher wahrscheinlich
1	gering	Eintritt eher unwahrscheinlich

	Bezeichnung	Beschreibung Eintrittshäufigkeit
4	Sehr häufig	Eintritt öfter als 1 x jährlich wahrscheinlich
3	Häufig	Eintritt 1 x in 1-5 Jahre wahrscheinlich
2	Mittel	Eintritt 1 x in 5-15 Jahren wahrscheinlich
1	selten	Eintritt weniger als 1 x in 15 Jahren wahrscheinlich

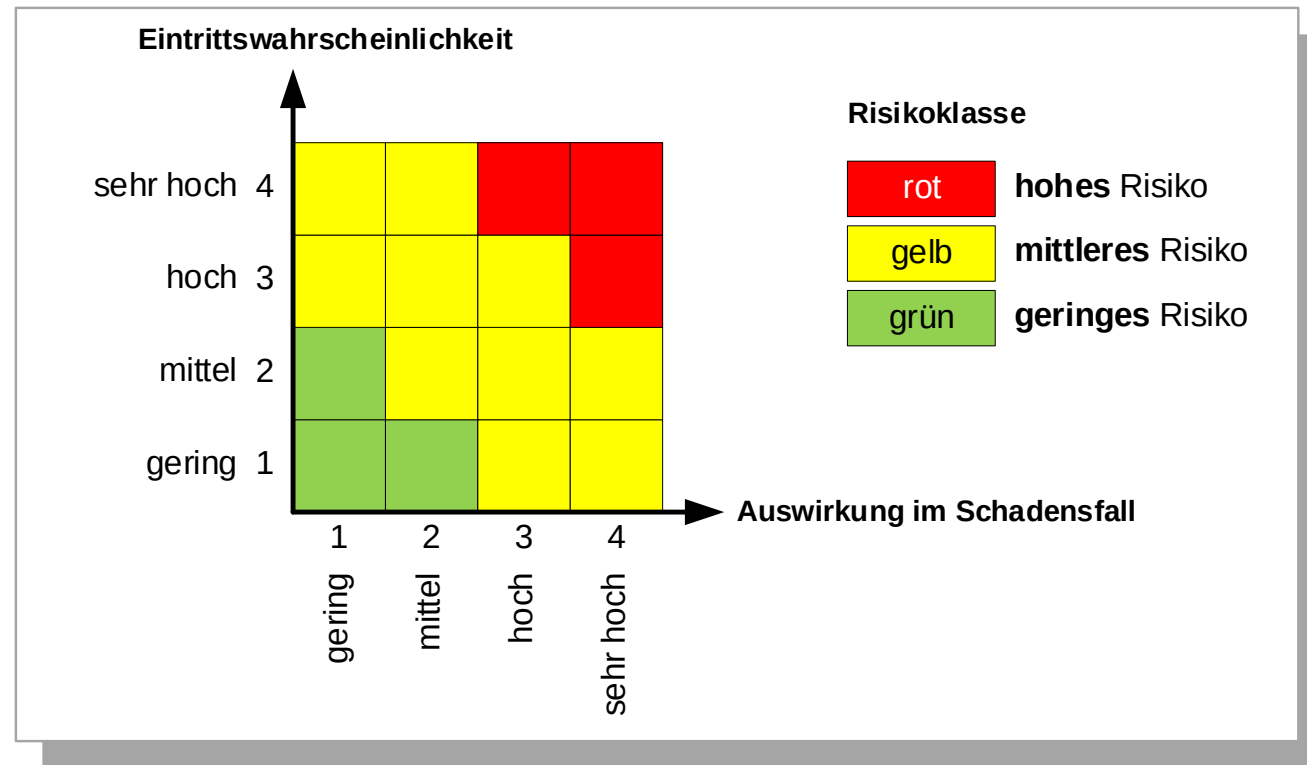
Übung (15min)

Definieren Sie die verschiedenen Schadensklassen für die gelisteten Schadensszenarien

	Auswirkungen im Schadensfall			
	1 Gering	2 Mittel	3 Hoch	4 Sehr hoch
Beeinträchtigung der körperlichen Unversehrtheit				
Imageschaden/ Reputationsverlust				
Finanzieller Schaden				

Festlegung der Rahmenbedingungen

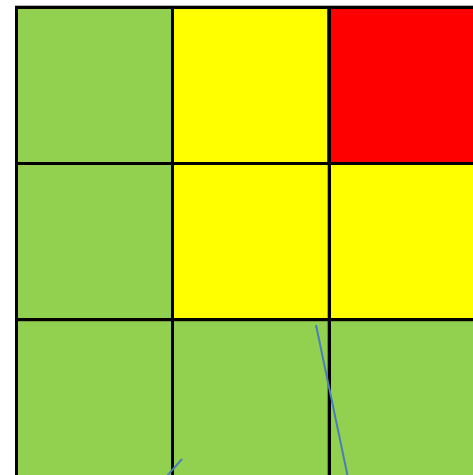
Risikomatrix



Risikomatrizen

- Angemessene Anzahl an Klassen für Eintrittswahrscheinlichkeit und Schadenshöhe wählen
- Eine größere Anzahl an Klassen führt zu einer höheren Granularität und damit zur besseren Unterscheidbarkeit von Risiken

3x3 Matrix

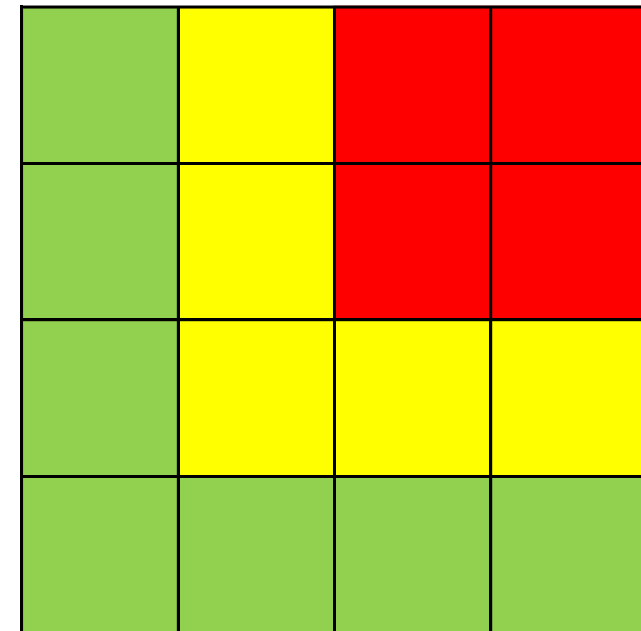


Risiko 1

Risiko 2

Kein erkennbarer Unterschied

4x4 Matrix



Festlegung der Risikoklassen

Beispiel zu Vorgaben zum Umgang mit Risiken und Risikoakzeptanzkriterien

Risikoklasse	Vorgaben zum Umgang mit Risiken dieser Klasse
hoch	– meldepflichtig, die Meldung muss umgehend erfolgen – Die Risiken müssen im Risikomanagement aufgenommen, dokumentiert und im regelmäßigen Reporting aufgeführt werden – Eine Risikobehandlung ist zwingend erforderlich.
mittel	– meldepflichtig – Die Risiken müssen im Risikomanagement aufgenommen, dokumentiert und im regelmäßigen Reporting aufgeführt werden – Eine Risikobehandlung ist erforderlich. Ausnahmen sind durch die GF zu genehmigen.
gering	– meldepflichtig – Risikobehandlung nur erforderlich wenn es vom Aufwand vertretbar ist. – Analysieren ob Kumulierungseffekte auftreten könnten

Festlegung der Risikoakzeptanzkriterien

Vorgaben zum Umgang mit Risiken und Risikoakzeptanzkriterien definieren

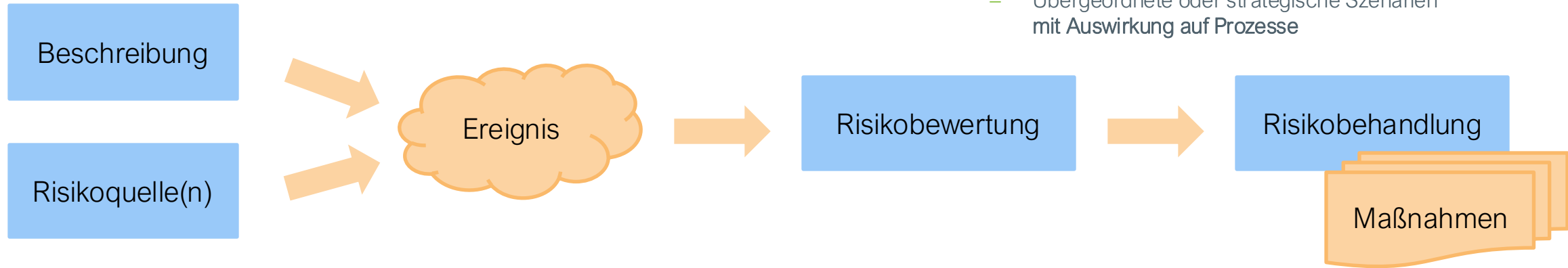
Risikoklasse	Akzeptanz	
hoch	unzulässig	
mittel	Leib & Leben: unzulässig	Andere: Geschäfts- führung
gering	Abteilungsleitung (nur seine/ihre Risiken)	

Risikoidentifikation

Risikoidentifikation

Ereignis-basierter Ansatz

- Top-Down-Sicht
- Übergeordnete oder strategische Szenarien mit Auswirkung auf Prozesse



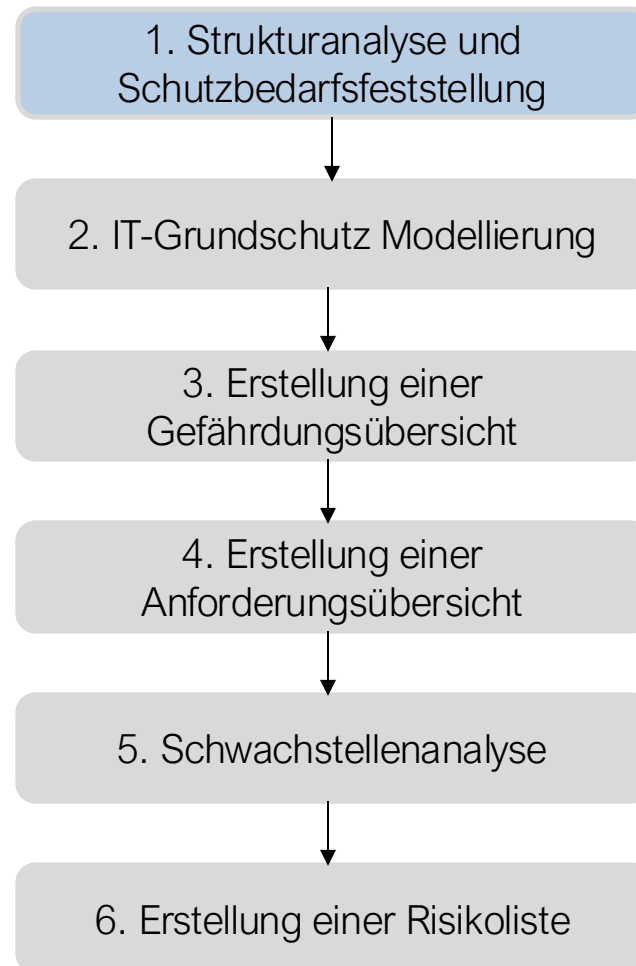
Asset-basierter Ansatz

- Bottom-Up-Sicht
- Untersuchung von Assets
- Ermöglicht spezifische Risikobehandlung auf detaillierter Ebene

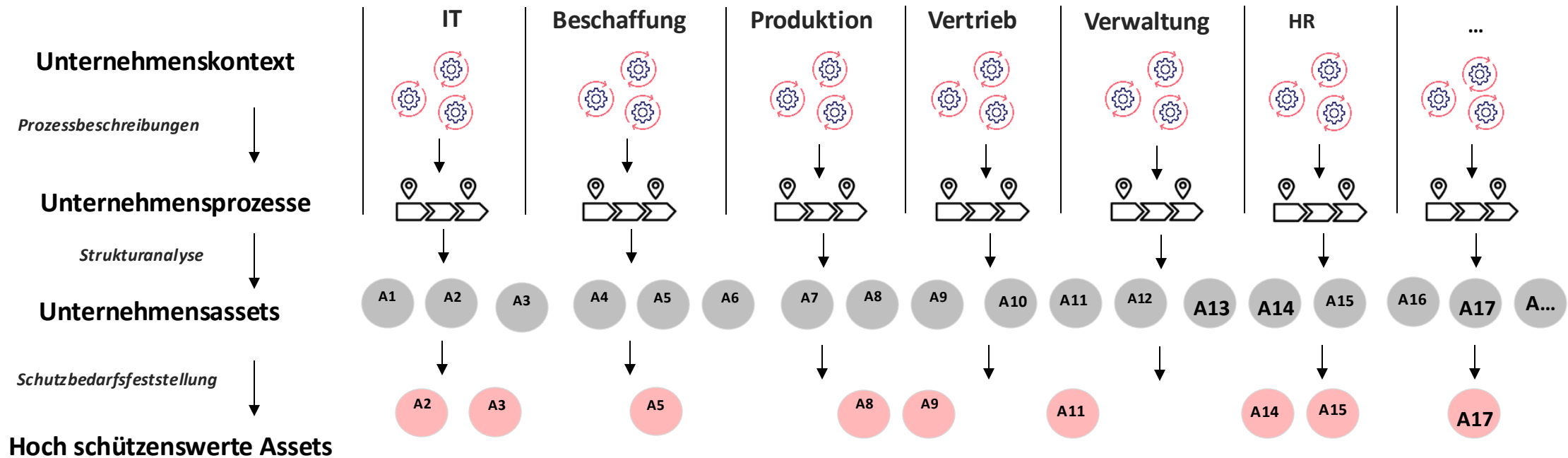


Asset-basierte Risikoidentifikation

Beispiel: Asset-basierte Risikoidentifikation



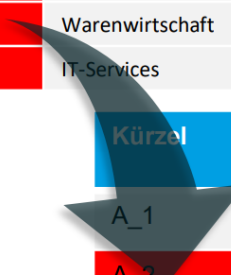
Strukturanalyse und Schutzbedarfsfeststellung



Strukturanalyse und Schutzbedarfsfeststellung

- ✓ Detaillierte Auflistung aller Assets und deren Abhängigkeiten
- ✓ Beginnend bei Geschäftsprozessen und Informationen
- ✓ Top-Down Approach: Von Prozess-Ebene auf Anwendungs-Ebene und danach auf IT-System Ebene
- ✓ Erleichtert die Schutzbedarfsfeststellung einzelner Assets durch eine mögliche Vererbung des Schutzbedarfs

Prozess-kürzel	Prozess	Prozessinhaber	Anhängig von Teilprozessen	Notwendige Anwendungen
HGP_1	Hauptgeschäftsprozess	Geschäftsleitung	TP_1, TP_2, TP_3, TP_4, TP_5	
TP_1	Vertrieb	Vertriebsleiter	TP_6	A_1, A_2, A_3
TP_2	Verwaltung (Auftragsbearbeitung)	Assistenz der GF	TP_6	A_1, A_2, A_3
TP_3	Einkauf	Einkaufsleiter	TP_6	A_1, A_2, A_3
TP_4	Produktion	Produktionsleiter	TP_2, TP_3, TP_6	
TP_5	Warenwirtschaft	Lagerleiter	TP_3, TP_4, TP_6	A_1, A_2, A_3
TP_6	IT-Services	IT-Leiter		



Kürzel	Anwendung	Nutzer	Admin	Notwendige Ressourcen
A_1	E-Mail-Programm	Alle Mitarbeiter	IT-Abteilung	
A_2	ERP-System	Geschäftsleitung, Vertrieb, Einkauf, Produktion, Warenwirtschaft	IT-Abteilung	S_1, S_2, ...

Schutzbedarfsfeststellung

Definition der Schutzbedarfsklassen:

Vertraulichkeit

Schutzbedarf	Vertraulichkeitsklasse
1 Sehr gering	Öffentlich
2 Gering	Intern
3 Mittel	Intern
4 Hoch	Vertraulich
5 Sehr hoch	Streng vertraulich

Verfügbarkeit

Schutzbedarf	max. tolerierbare Ausfallzeit
1 Sehr gering	>3 Tage
2 Gering	1-3 Tage
3 Mittel	12-24 Stunden
4 Hoch	4-12 Stunden
5 Sehr hoch	0-4 Stunden

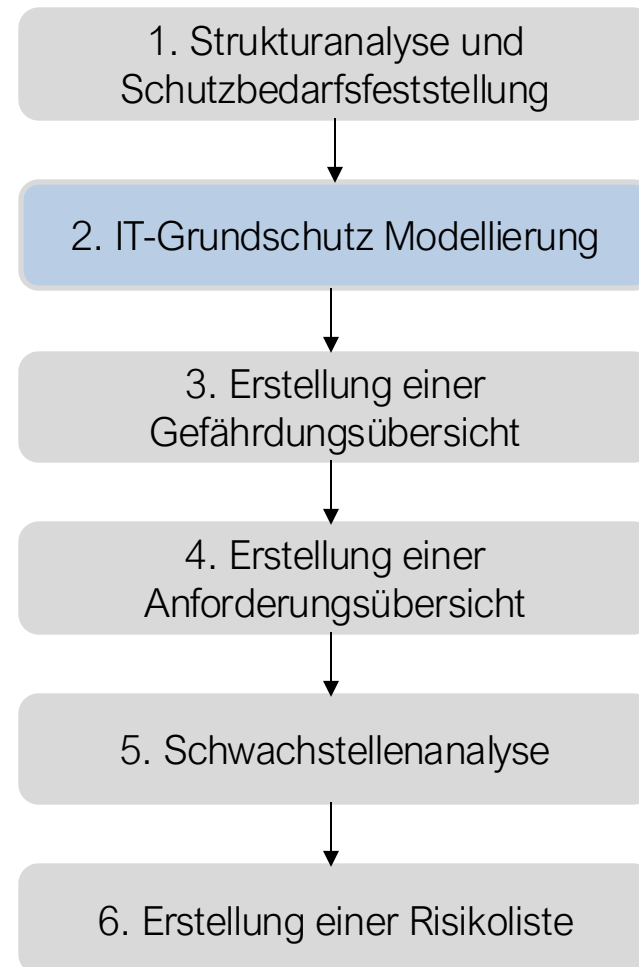
Integrität

Schutzbedarf	Zuweisbarkeit	Lesbarkeit	Zeitgenauigkeit	Originalität	Korrektheit
	Die Verarbeitung muss eindeutig zuweisbar sein, zu Personen oder Systemen	Daten müssen dauerhaft lesbar bleiben; Daten müssen jederzeit lesbar sein; Für den Lebenszyklus der Daten	Der Zeitpunkt der Verarbeitung muss gelogged werden	Es muss erkennbar sein, ob es sich um Originaldaten oder um Kopien der Daten handelt	Es darf keine Bearbeitung oder Fehlerkorrektur ohne Dokumentation der Änderungen geschehen
1 Sehr gering		X			
2 Gering	X	X			
3 Mittel	X	X	X		
4 Hoch	X	X	X	X	
5 Sehr hoch	X	X	X	X	X

Beispiel: Asset-basierte Risikoidentifikation - Schutzbedarfsfeststellung

Schutzbedarfsfeststellung der Anwendung			
	Schutzziel	Schutzbedarf	Begründung
Active Directory (AD)	Vertraulichkeit:	5	Im Active Directory sind sensible Mitarbeiterdaten (z.B. Passwörter) gespeichert.
	Integrität:	5	Alle Mitarbeiter identifizieren sich mit Passwörtern, daher ist der Schutzbedarf der Integrität der gespeicherten Daten im Active Directory sehr hoch.
	Verfügbarkeit:	5	Bei Ausfall des Authentisierungssystems können Mitarbeiter sich nicht identifizieren; eine Ausführung von IT-Verfahren ist dann nicht möglich. Ein Ausfall von mehr als 4 Stunden ist nicht hinnehmbar.

Beispiel: Asset-basierte Risikoidentifikation

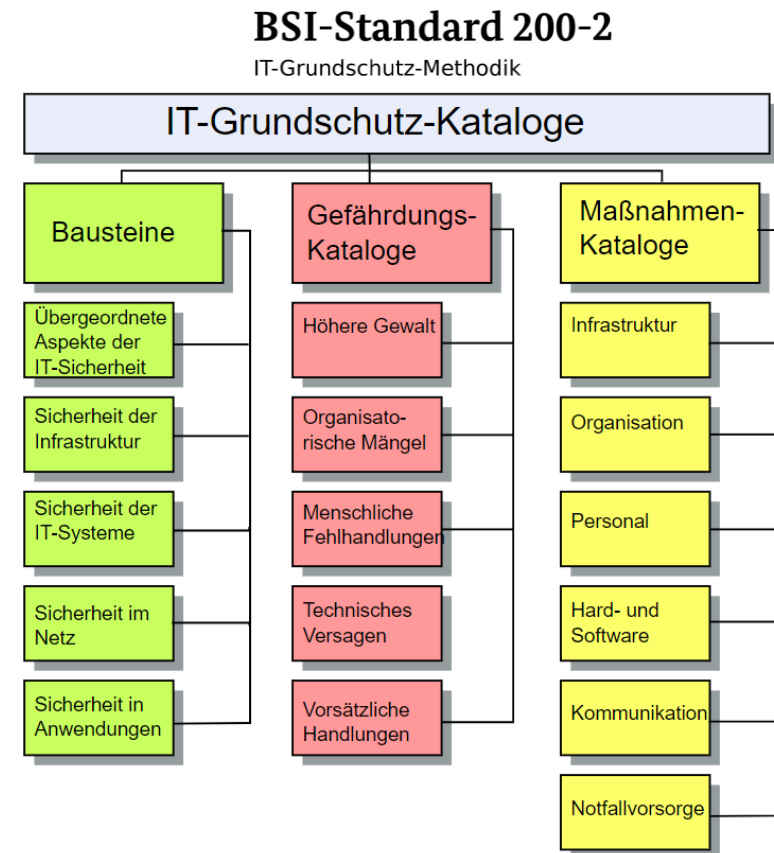


Beispiel: Asset-basierte Risikoidentifikation

2.) IT-Grundschutz Modellierung gemäß BSI 200-2 IT-Grundschutz-Methodik :

IT Grundschutz-Kompendium beinhaltet:

- ✓ IT Grundschutz Bausteine
- ✓ Gefährdungskataloge
- ✓ Maßnahmenkataloge



Beispiel: Asset-basierte Risikoidentifikation

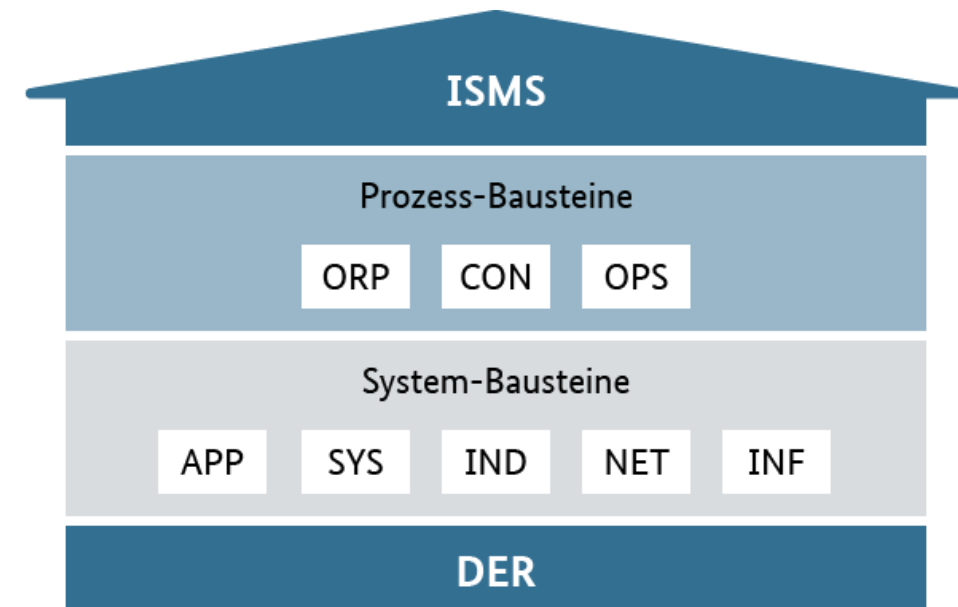
2.) IT-Grundschutz Modellierung gemäß BSI 200-2 IT-Grundschutz-Methodik :

Prozess-Bausteine:

- ✓ ISMS: Sicherheitsmanagement
- ✓ ORP: Organisation und Personal
- ✓ CON: Konzeption und Vorgehensweisen
- ✓ OPS: Betrieb

System-Bausteine:

- ✓ APP: Anwendungen
- ✓ SYS: IT-Systeme
- ✓ IND: Industrielle IT
- ✓ NET: Netze und Kommunikation
- ✓ INF: Infrastruktur



Beispiel: Asset-basierte Risikoidentifikation

2.) IT-Grundschutz Modellierung gemäß BSI 200-2 IT-Grundschutz-Methodik :

Beispiel - [SYS.1.5: Virtualisierung](#):

Spezifische Gefährdungen:

- ✓ Fehlerhafte Planung der Virtualisierung
- ✓ Fehlerhafte Konfiguration der Virtualisierung
- ✓ Unzureichende Ressourcen für virtuelle IT-Systeme
- ✓ ...

Elementare Gefährdungen:

- ✓ G 0.18 Fehlplanung oder fehlende Anpassung
- ✓ G 0.19 Offenlegung schützenswerter Informationen
- ✓ G 0.20 Informationen oder Produkte aus unzuverlässiger Quelle
- ✓ G 0.21 Manipulation von Hard- oder Software
- ✓ G 0.22 Manipulation von Informationen

Basis-Anforderungen:

- ✓ Einspielen von Aktualisierungen und Sicherheitsupdates
- ✓ Sicherer Einsatz virtueller IT-Systeme
- ✓ Sichere Konfiguration virtueller IT-Systeme
- ✓ ...

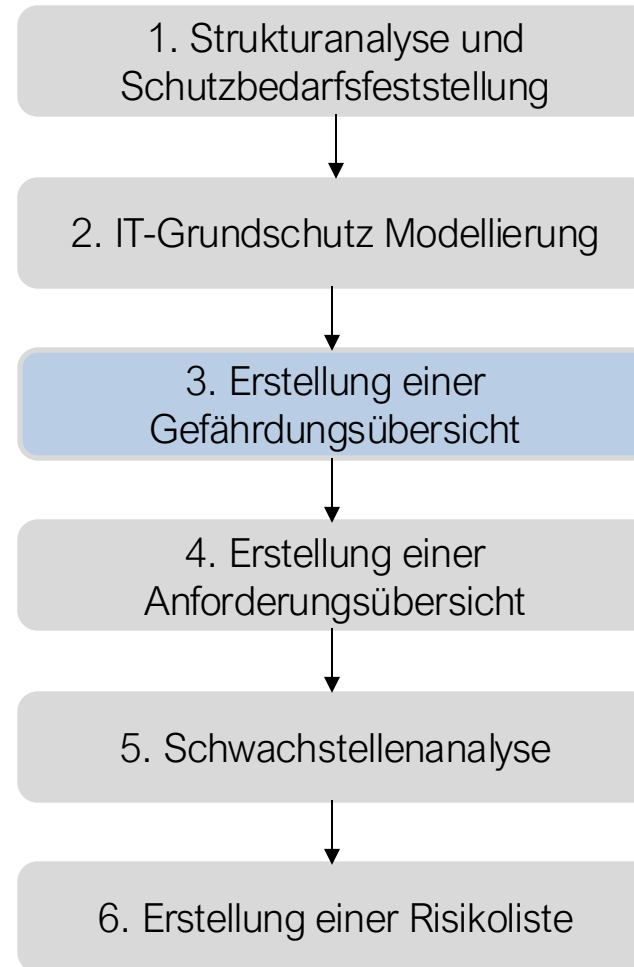
Standard Anforderungen:

- ✓ Netzplanung für virtuelle Infrastrukturen
- ✓ Einführung von Verwaltungsprozessen für virtuelle IT-Systeme
- ✓ Einheitliche Konfigurationsstandards für virtuelle IT-Systeme
- ✓ ...

Anforderungen bei erhöhtem Schutzbedarf:

- ✓ Verwendung von hochverfügbaren Architekturen
- ✓ Härtung des Virtualisierungsservers
- ✓ Rechte-Einschränkung der virtuellen Maschinen
- ✓ ...

Beispiel: Asset-basierte Risikoidentifikation



Beispiel: Asset-basierte Risikoidentifikation

3.) Erstellung einer Gefährdungsübersicht:

Elementare Gefährdungen:

Virtualisierungsserver S1
Vertraulichkeit: hoch Integrität: hoch Verfügbarkeit: hoch
G 0.14 Ausspähen von Informationen/Spionage G 0.15 Abhören G 0.18 Fehlplanung oder fehlende Anpassung G 0.19 Offenlegung schützenswerter Informationen G 0.21 Manipulation von Hard- oder Software G 0.22 Manipulation von Informationen G 0.23 Unbefugtes Eindringen in IT-Systeme G 0.25 Ausfall von Geräten oder Systemen G 0.26 Fehlfunktion von Geräten oder Systemen G 0.28 Software-Schwachstellen oder -Fehler G 0.30 Unberechtigte Nutzung oder Administration von Geräten und Systemen G 0.31 Fehlerhafte Nutzung oder Administration von Geräten und Systemen G 0.32 Missbrauch von Berechtigungen G 0.40 Verhinderung von Diensten (Denial of Service) G 0.43 Einspielen von Nachrichten G 0.45 Datenverlust G 0.46 Integritätsverlust schützenswerter Informationen

Spezifische Gefährdungen:

- ✓ Fehlerhafte Planung der Virtualisierung
- ✓ Fehlerhafte Konfiguration der Virtualisierung
- ✓ Unzureichende Ressourcen für virtuelle IT-Systeme
- ✓ Informationsabfluss oder Ressourcen-Engpass durch Snapshots
- ✓ Ausfall des Verwaltungsservers für Virtualisierungssysteme
- ✓ Missbräuchliche Nutzung von Gastwerkzeugen
- ✓ Kompromittierung der Virtualisierungssoftware

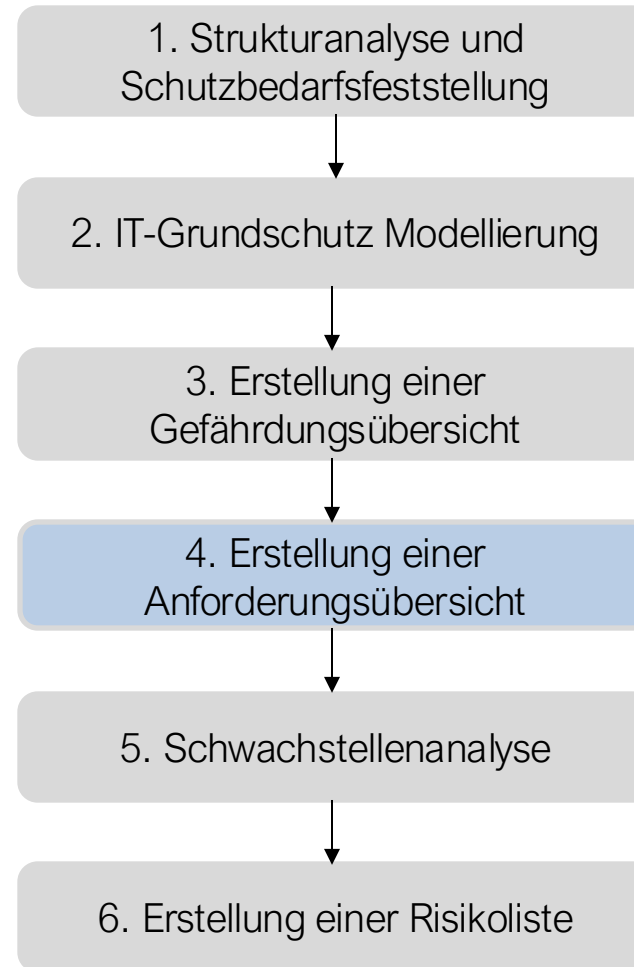
Beispiel: Asset-basierte Risikoidentifikation

3.) Erstellung einer Gefährdungsübersicht:

Zusätzliche bzw. weitere Gefährdungen:

- ✓ Identifizierung von **weiteren möglichen Gefährdungen** pro betrachtetem Zielobjekt
 - Wenn es keinen geeigneten IT-Grundschutz Baustein für ein Zielobjekt gibt
 - Wenn Zielobjekt in Einsatzszenario betrieben wird, das im IT-Grundschutz Kompendium nicht vorgesehen ist
 - ✓ Empfehlung: Workshops, Brainstorming mit Experten
 - ✓ **Ergebnis:** Übersicht von elementaren, spezifischen und zusätzlichen Gefährdungen, die auf betrachtete Zielobjekte einwirken können.
-

Beispiel: Asset-basierte Risikoidentifikation



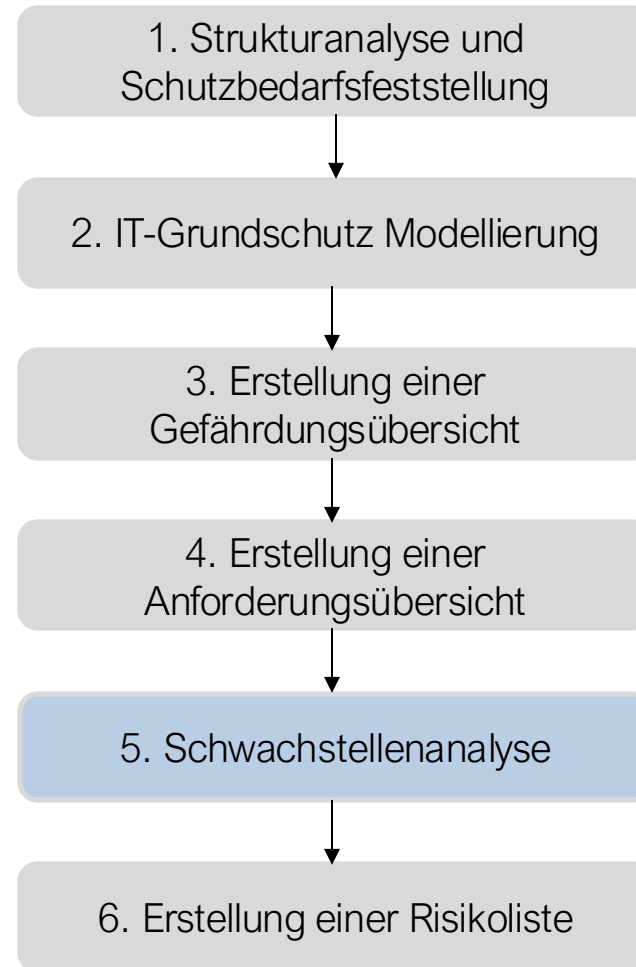
Beispiel: Asset-basierte Risikoidentifikation

4.) Erstellung einer Anforderungsübersicht:

Beispiel: IT-Grundschutz Baustein - NET.1.1: Netzarchitektur und –design:

Soll-Ist Vergleich bestehender und erforderlicher Schutzmaßnahmen					
Basis Anforderungen	Erfüllt	Standard Anforderungen	Erfüllt	Anforderungen für erhöhten Schutzbedarf	Erfüllt
Sicherheitsrichtlinie für das Netz		Spezifikation der Netzarchitektur		Hochverfügbare Netz- und Sicherheitskomponenten	
Dokumentation des Netzes		Spezifikation des Netzdesigns			
Anforderungsspezifikation für das Netz		P-A-P-Struktur für die Internet-Anbindung		Hochverfügbare Realisierung von Netzanbindungen	
Netztrennung in Zonen		Separierung der Infrastrukturdienste			
Client-Server-Segmentierung		Zuweisung dedizierter Subnetze für IPv4/IPv6-Endgerätegruppen		Schutz vor Distributed-Denial-of-Service	
Endgeräte-Segmentierung im internen Netz		Separierung des Management-Bereichs			

Beispiel: Asset-basierte Risikoidentifikation



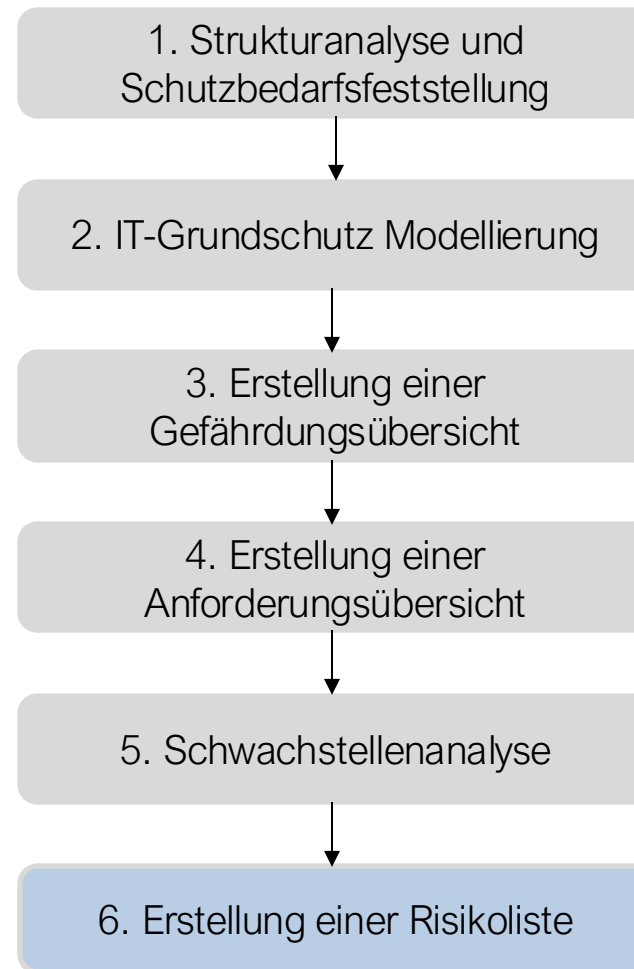
Beispiel: Asset-basierte Risikoidentifikation

5.) Schwachstellenanalyse:

Beispiel: IT-Grundschutz Baustein - OPS.1.1.4 Schutz vor Schadprogrammen:

Soll-Ist Vergleich bestehender und erforderlicher Schutzmaßnahmen								
Basis Anforderungen	Erfüllt	Kommentar	Standard Anforderungen	Erfüllt	Kommentar	Anforderungen für erhöhten Schutzbedarf	Erfüllt	Kommentar
Erstellung eines Konzepts für den Schutz vor Schadprogrammen			Meldung von Infektionen mit Schadprogrammen	X		Nutzung spezieller Analyseumgebungen	X	
Nutzung systemspezifischer Schutzmechanismen	X					Einsatz mehrerer Scan-Engines		
Auswahl eines Virenschutzprogrammes	X					Einsatz von Datenträgerschleusen	X	
Betrieb und Konfiguration von Virenschutzprogrammen	X					Umgang mit nicht vertrauenswürdigen Dateien	X	
Regelmäßige Aktualisierung der eingesetzten Virenschutzprogramme und Signaturen	X					Auswahl und Einsatz von Cyber-Sicherheitsprodukten gegen gezielte Angriffe	X	
Sensibilisierung und Verpflichtung der Benutzer	X							

Beispiel: Asset-basierte Risikoidentifikation



Beispiel: Asset-basierte Risikoidentifikation

6.) Erstellung einer Risikoliste:

- ✓ Mindestfaktoren, um ein Risiko zu beschreiben:
 - **Wer** (Angreifer / Gefahrenquelle)
 - Tut **Was** (Schwachstelle, Angriff, Bedrohung)
 - Gegen **Wen** (Asset, Wert, Ziel, Opfer)
 - Mit welcher **Auswirkung** (Schaden, welches Interesse des Unternehmens wird verletzt?)

	Wer (Angreifer)	tut was (Bedrohung)	gegen wen (Ziel)	mit welcher Auswirkung?
1				
2				
3				
4				
5				
6				

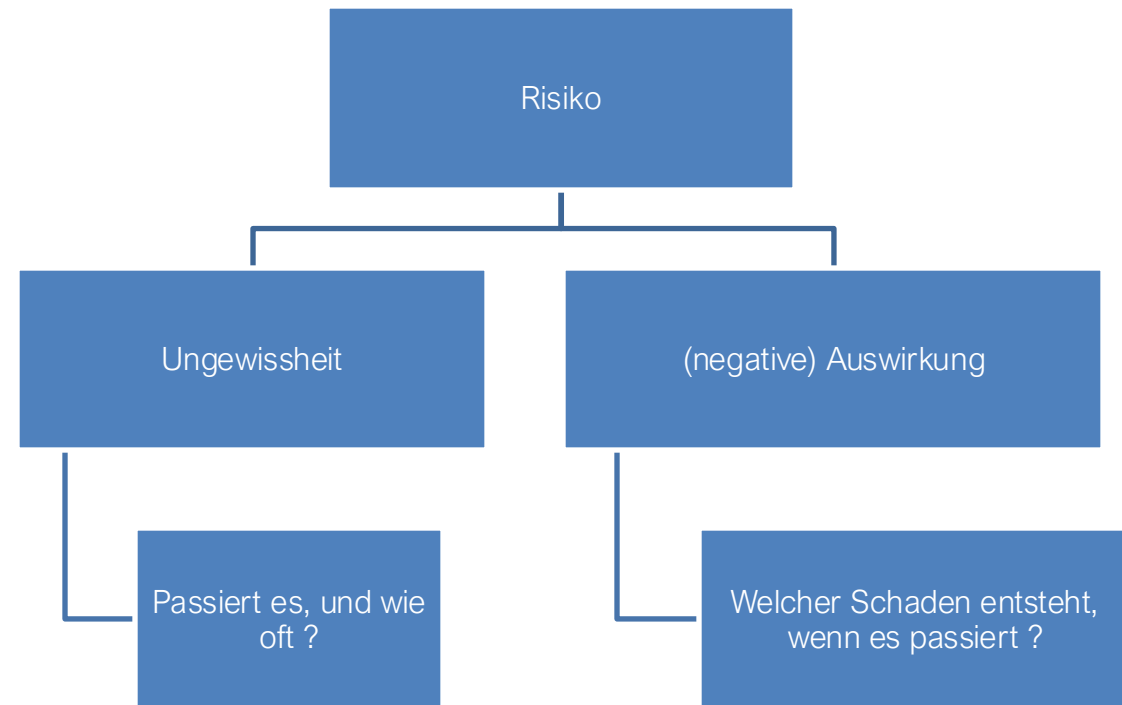
Risikobewertung

Analyse eines Risikos

1. Zerlegung
2. Bewertung der einzelnen Faktoren
3. Berechnung des Risikos

Nutzen der Zerlegung:

- Leichtere Einschätzung
- Ableitung aus vorhandenen Daten
- Weitere Zerlegung möglich



Qualitative Methoden

- ✓ Methoden mit Faktoren, die auf Ordinalskalen basieren
 - z.B. verbale Klassen wie „niedrig“ / „mittel“ / „hoch“
 - z.B. Farben (grün, gelb, rot)
 - ✓ Berechnung der Ergebnisse durch Matrizen oder „Formeln“
 - z.B. „Risiko = Auswirkung x Wahrscheinlichkeit“
 - ✓ Qualitative Methoden eignen sich zur Einschätzung schwer quantifizierbarer Risiken
-

Qualitative Methoden

Vorteile

- ✓ Intuitiv verständlich
- ✓ Leicht zu erklären und verwenden
- ✓ Hoher Bekanntheitsgrad
- ✓ Bessere Bewertung von Risiken, die schwer quantifizierbar sind Interviews, Fokusgruppen und Expertenbewertungen ermöglichen die Einbeziehung von persönlichen Erfahrungen

Nachteile

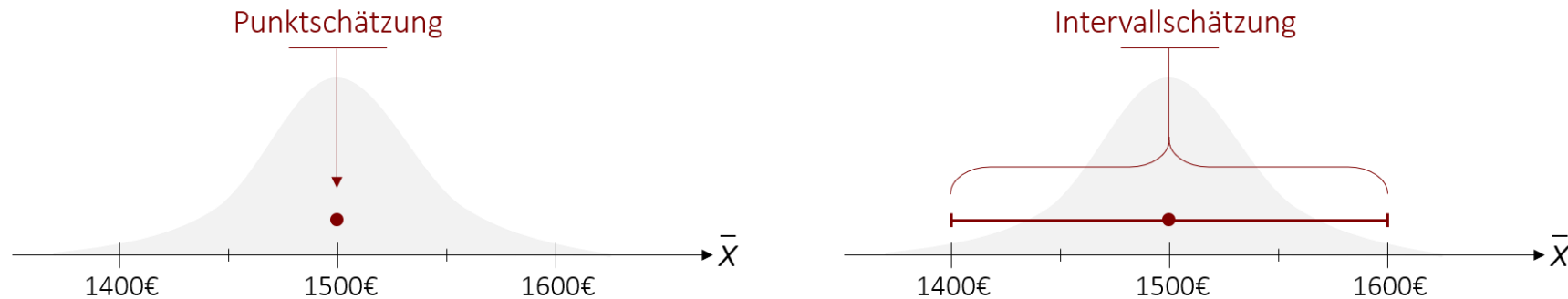
- ✓ Verwendung fehlerhafter Matrizen
- ✓ Anfällig für Fehler in der Festlegung der Kategorien bzw. Wertebereiche
- ✓ Wenig Aussagekraft, wenn sich Risiken das gleiche Feld teilen
- ✓ Keine empirische Basis

Quantitative Methoden

- ✓ Methoden mit Faktoren, die auf metrischen Skalen basieren
 - z.B. Eintrittswahrscheinlichkeit in Prozent oder Häufigkeit pro Jahr
 - z.B. Schaden in Euro pro Vorfall
 - ✓ Fokus: Berechnung von finanziellen Schäden
 - ✓ Möglicher Vergleich von Kosten und Nutzen von Sicherheitsmaßnahmen
 - Einfachere Messbarkeit der Effektivität von Maßnahmen
 - Einfachere Priorisierung der Maßnahmen
 - ✓ Berücksichtigung von statistischen Daten und historischen Trends
 - ✓ Es werden meistens Tool für quantitative Risikobewertungen verwendet (z.B. CRISAM)
-

Quantitative Methoden – Abbildung von Unsicherheiten

- ✓ Abbildung von Unsicherheiten in der Abschätzung durch Konfidenzintervalle
 - z.B. 90% Konfidenzniveau – „der Schaden wird zwischen 5.000 und 70.000 Euro liegen“
- ✓ Höhere Breite des Intervalls = Höhere Unsicherheit



Quelle: <https://statistikgrundlagen.de/ebook/chapter/konfidenzintervalle/>

Beispielabschätzung quantitativ

Bedrohung	Schaden	Frequenz / Jahr	Schaden / Ereignis	Schaden / Jahr
DDoS-Angriff	Verfügbarkeit	1,50	15.000,- €	22.500,- €
SQL-Injection	Data Breach	0,40	60.000,- €	24.000,- €
Bösartiger Insider	Data Breach	0,10	150.000,- €	15.000,- €
Brand im RZ	Datenverlust, Verfügbarkeit	0,05	250.000,- €	12.500,- €
Fehler im Algorithmus	Kundenzufriedenheit	0,20	100.000,- €	20.000,- €

Quantitative Methoden

Vorteile

- ✓ Belastbare Ergebnisse
- ✓ Saubere Differenzierung, auch bei kleinen Unterschieden
- ✓ Kontrollierte Subjektivität
- ✓ Ermöglicht Ableitung von sinnvollen Investitionen für Maßnahmen
- ✓ Erwartungswerte = Rückstellungen
- ✓ Kann Verteilungsfunktionen abbilden

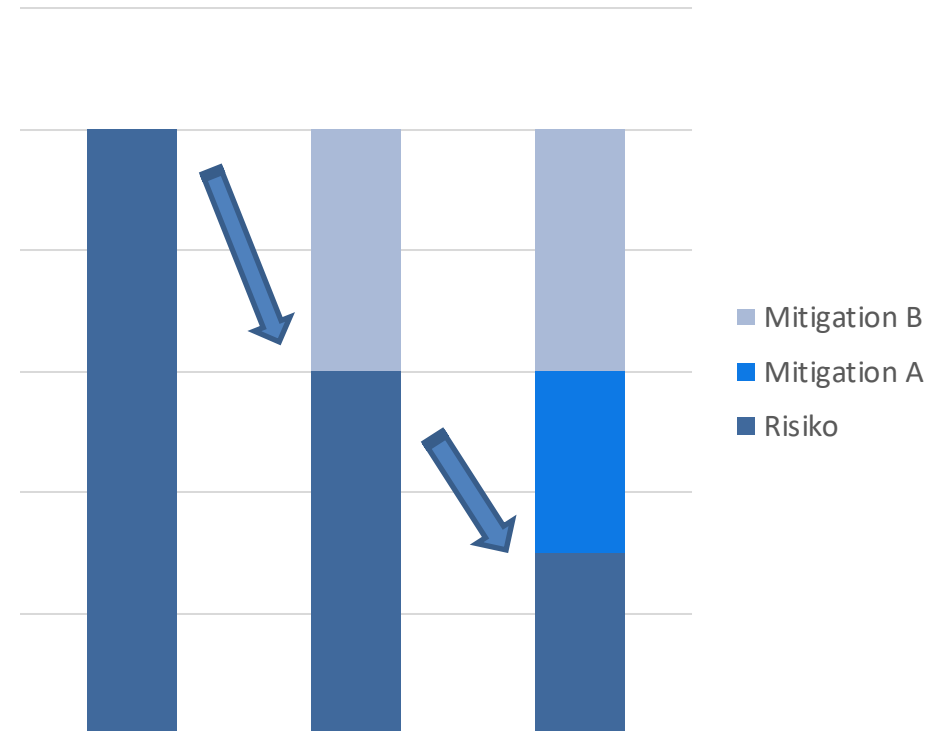
Nachteile

- ✓ Höhere Komplexität
- ✓ (statistische Methoden) erfordern Werkzeuge, nicht mehr im Kopf oder auf Papier abbildbar
- ✓ Erklärungs- und Verständnisbedürftig

Risikobehandlung

Risikobehandlung - Ziele

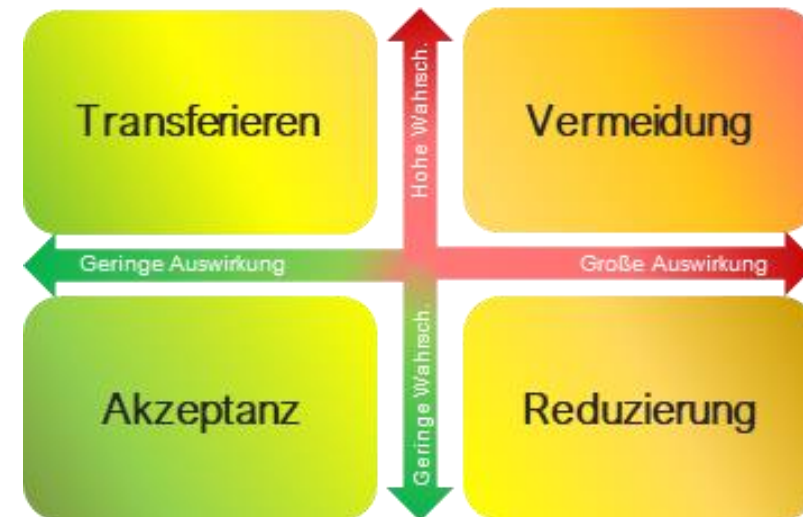
- ✓ Reduzierung des Risikos auf ein akzeptables Niveau
- ✓ Festlegung sinnvoller Maßnahmen
- ✓ Berücksichtigung wirtschaftlicher Aspekt
 - Personelle und finanzielle Ressourcen



Risikobehandlung - Strategien

4 Basisstrategien:

- ✓ Vermeidung:
 - Gewisse Tätigkeiten/Prozesse werden nicht durchgeführt, um das Risiko zu eliminieren
- ✓ Reduktion
 - Risikoreduzierende Maßnahmen werden implementiert
- ✓ Transfer
 - Verlagerung der Verantwortung des Risikos (z.B. Abschluss einer Versicherung)
- ✓ Akzeptanz



Risikobehandlungsplan – Beispiel

Risiko	Strategie	Konkrete Maßnahme	Umsetzung bis	verantwortlich	Kosten	Auswirkung auf Risiko	Restrisiko
1	Reduzierung	Neue Firewall einrichten	31.03.	Meier	25.000,- € 5.000,- € p.a.	EW -20%	52.000,- €
1	Transfer	Cybersversicherung abschließen	31.04.	Dr. Hubertus	30.000,- € jährlich	A -80%	10.000,- €
2	Vermeidung	Onlineshop schließen	15.03.	Dr. Hubertus	5.000,- €	eliminiert	0
3	Reduzierung	Neue Firewall einrichten	31.03.	Meier	(25.000,- €)	EW -25%	60.000,- €
3	Reduzierung	IDS installieren	15.05.	Meier	40.000,- € 12.000,- € p.a.	EW -10% A -40%	15.000,- €

Überwachung und Verbesserung

Kontinuierliche Verbesserung des Risikomanagement Prozesses

- ✓ Ziel der Erhöhung der Wirksamkeit des Risikomanagement-Prozesses
 - ✓ Optimierung der Schutzmaßnahmen
 - ✓ Verbesserung in einzelnen Schritten:
 - Definition von Zielen und Anforderungen des Risikomanagement-Prozesses
 - Ggf. Neubewertung von Risiken
 - Identifikation von Verbesserungsmöglichkeiten
 - Maßnahmen zur Verbesserung der Risikobewertung und –kontrolle
 - Überwachung der Ergebnisse der Verbesserungsmaßnahmen
-

Key Performance Indicators vs Key Risk Indicators

Key Performance Indicators (KPIs) sind Messgrößen, die verwendet werden, um den Erfolg oder die Effektivität einer bestimmten Aktivität oder eines bestimmten Prozesses zu bewerten.

Im Gegensatz zu KPIs, konzentrieren sich **Key Risk Indicators (KRIs)** auf die Überwachung von potenziellen Risiken.

- ✓ Dienen dazu:
 - die Wirksamkeit von Maßnahmen zur Risikominderung und -kontrolle zu messen und zu bewerten
 - die Wirksamkeit der Risikomanagement-Strategie zu messen, Risiken besser zu verstehen und ihre Ressourcen gezielter einzusetzen
 - ✓ Die richtige Auswahl von KRI und KPI ist entscheidend für eine hohe Aussagekraft und Relevanz
 - ✓ Für KRI/KPI muss immer ein gewisser Zielwert definiert werden
-

Übung (10min)

Schlagen Sie 3 verschiedene KRI vor:

- Definieren Sie in der Beschreibung, was das Ziel der Kennzahl ist und wie sie erhoben wird
- Definieren Sie einen Verantwortlichen für die Erhebung der Kennzahl
- Definieren Sie einen Schwellwert, ab dessen Überschreitung automatisch Maßnahmen gesetzt werden

KRI	Beschreibung (Ziel des KRI und Art der Erhebung)	Verantwortlicher	Schwellenwert
Anzahl erfolgreicher Angriffe auf das Netzwerk pro Monat	Eine hohe Anzahl erfolgreicher Angriffe auf das Netzwerk kann ein Indiz für Schwachstellen in der Netzwerk-sicherheit sein. Einige Möglichkeiten zur Erhebung dieses Indikators könnten die Überwachung von Netzwerklogs, die Auswertung von Intrusion Detection Systemen (IDS) oder das Scannen des Netzwerks auf Schwachstellen sein.	IT-Abteilung	5 erfolgreiche Angriffe pro Monat
...	...	...	...

Risikokommunikation

Risikobericht

Ein Risikobericht ist wichtig, um das Risikoprofil des Unternehmens zu kennen und zu verstehen.

- ✓ Ermöglicht eine gezielte **Steuerung und Überwachung** aller Risiken
 - ✓ **Grundlage bei der Entscheidungsfindung** und der Priorisierung von Maßnahmen zur Risikominderung
 - ✓ **Steigerung der Transparenz** und Verständlichkeit der Risikolage im Unternehmen
 - ✓ Risikobericht als **vertrauensbildende Maßnahme** für Stakeholder
 - ✓ Keine verpflichtende Form eines Risikoberichts vorgeschrieben
-

Risikoreporting

- ✓ Die **Häufigkeit** des Risikoreportings hängt von verschiedenen Faktoren ab:
 - Größe des Unternehmens
 - Komplexität des Risikomanagementsystems
 - Risikosituation des Unternehmens

In der Regel sollte das Risikoreporting jedoch mindestens **einmal pro Jahr** (bei großen Unternehmen auch einmal pro Quartal sinnvoll) erfolgen, um die Geschäftsführung auf dem Laufenden zu halten.

- ✓ Das **Format** des Risikoreportings hängt von folgenden Faktoren ab:
 - Zielgruppe
 - Verfügbare Ressourcen
 - Bereitzustellende Informationen

Einige der gängigen Formate für das Risikoreporting sind schriftliche **Berichte, Dashboards, Präsentationen und Meetings**.

Advanced Security and Privacy

Informationssicherheits-Risikomanagement

Dipl. Ing. Dr. Kevin Theuermann MSc